Book Exchange Platform

Software Test Plan

This plan defines how the team will verify the Book Exchange Platform against SRS v1.0 and SAD v1.0. It provides test cases, owners, environments, milestones and acceptance gates. All tests are initially Not run; this document reports no executed or passing tests.

Document control	Value
Version	1.0
Date	27 October 2026
Status	Submission baseline; implementation and test execution pending
Authors	Nishkal - DevOps and coordination; Abhiram - Auth; Manoj - Listings; Ravish - UI, documentation and demo.
Schedule	Sprint 1: 27-31 Oct; Sprint 2: 2-7 Nov; presentations from 9 Nov 2026
Revision	1.0 - Project baseline aligned to the updated 16-page plan and user-confirmed role swap.
Approval	Team and TA review pending; no signature or approval is claimed.

Contents

1 Introduction; 2 Test items; 3 Features tested; 4 Exclusions; 5 Strategy; 6 Environment; 7 Schedule; 8 Deliverables; 9 Responsibilities; 10 Risks; 11 Dependencies; 12 Suspension; 13 Cases and traceability; 14 Reporting; 15 Approvals.

1 Introduction and 2 Test items

Purpose: detect functional, security and integration defects before demonstrations and provide evidence linked to requirements. Scope: browser UI, API services, relational database, matching algorithm, CI and deployment. Test items are the versioned backend/frontend, migrations, fixtures, Docker images and deployment configuration. Record the Git commit for each run.

3 Features to be tested

Scope	Requirements
Sprint 1	F-001..004, F-010..013; NF-001/003/004/006; SR-001/002/004/005/006.
Sprint 2	F-020..026, F-030/031/040; NF-002/005; SR-003/007 plus full Sprint 1 regression.
Cross-cutting	Error contracts, validation, authorization, migration integrity, concurrent reservations and secret-free responses/logs.

4 Features not tested

Exclude payment, shipping, university SSO, SMS/email delivery and third-party cloud internals because they are outside the release. Observe the deployed provider through health and TLS checks; do not claim to certify its infrastructure. A mocked active-exchange guard in Sprint 1 does not replace Sprint 2 real-database integration testing.

5 Test approach and strategy

Unit: deterministic hashing/token/rate-limit, validation, score and transition functions. Integration: FastAPI with an isolated PostgreSQL database and real migrations/constraints. System: browser register -> login -> create -> search -> edit -> delete, then request -> match -> exchange -> return. Acceptance: teammate checks SRS criteria on the deployed build and records evidence. Regression: all relevant automated tests on every PR, full suite on main before demo.

5.1 Security validation

Verify credential redaction, token tampering/expiry/logout, ownership bypass, profile privilege escalation, SQL injection handling, throttling, TLS and contact privacy. Use synthetic accounts. Test the API directly so a hidden UI control cannot conceal a server authorization defect. Restrict load and negative tests to team-owned test environments.

5.2 Entry and exit

Entry: requirement and API baselines available, test environment and synthetic data ready, migrations pass, selected feature build available. Exit: 100% planned in-scope cases executed, all high-priority criteria passed, no critical/high unresolved defects, required CI green, coverage thresholds met, reviewed PR merged and evidence linked. Performance thresholds require recorded measurements; an unrun test cannot be waived by changing the RTM to A.

5.3 Test isolation and concurrency

Use independent test database/schema and reset fixtures per test. Inject a controllable clock for JWT expiry and rate-limit windows. Verify race tests with separate DB sessions and synchronization; a serial unit test cannot prove locking. Never seed or reset production data as part of CI.

6 Test environment

Item	Baseline
Runtime	Python 3.11; Node 20; PostgreSQL 15 + pg_trgm; Docker Compose; pin actual versions in the scaffold.
Tools	pytest/httpx/pytest-cov; Ruff; Locust; browser DevTools; GitHub Actions; Jira defects.
Accounts	Synthetic students A/B/C, active admin and inactive student. Use configured test domain, not invented institutional addresses.
Data	Small deterministic fixtures plus 20 synthetic users, ~2,000 books and 10,000 listings for search load. 1,000 open requests for matching benchmark.
Deployment	HTTPS staging/demo with persistent Postgres; actual host, resources and sleep behavior recorded in reports.
Secrets	Environment variables / CI secrets; no real .env, JWT secret or deploy hook in source or test reports.

7 Test schedule

Date	Work / evidence
27 Oct	Baseline SRS/SAD/STP; prepare backlog and review test IDs; no execution claimed.
28 Oct	Scaffold/migrations/CI, auth helpers, registration and create-listing tests.
29 Oct	Login/rate-limit, search/mine, API/UI integration and deployment smoke tests.
30 Oct	Logout/profile, owner mutations, performance, UX and clean-clone regression. PRs by 14:00; merges target 18:00 IST.
31 Oct	Buffer and Sprint 1 acceptance; capture burndown; carry over unfinished work transparently.
2-7 Nov	Requests/matching/exchanges/admin, concurrency/privacy, TLS/uptime and full final regression.
From 9 Nov	Presentation and demonstration using verified build/evidence.

8 Test deliverables and 9 Responsibilities

Deliverables: this plan, automated tests, manual case records, synthetic fixtures, seed and load scripts, CI/coverage artifacts, defect reports, performance reports, uptime/TLS evidence and a final test summary. Each result includes case ID, environment, commit, date, expected/actual result, status and evidence path. Use docs/test-results, docs/perf-sprint1.md and docs/DEVIATIONS.md as appropriate.

Owner	Responsibility
Nishkal	DevOps, test environment, migrations, CI/deployment, health/uptime, sprint coordination and independent review of Auth PRs.
Abhiram	Auth/profile/security tests; auth module coverage >85%; independent scaffold review.
Manoj	Listings/search/ownership/query safety, seed and load tests; proposed Sprint 2 requests/matching.
Ravish	Browser/manual UX, API integration, RTM maintenance, deviations and demo; collate evidence without inventing passes.
Whole team	Review requirements and sprint scope; reproduce defects; verify acceptance. TA approval remains external and pending.

10 Risks and mitigation

Late shared scaffold delays dependent work: use contract fixtures, then rerun against real endpoints. Missing domain or hosting settings block acceptance: record B with owner. In-memory limiter and mocked exchange checks limit realism: document and retest. Free-host cold starts distort load results: publish both cold and warm behavior. Keep test accounts/data isolated.

11 Assumptions and dependencies

The team supplies university domains, account identities and accessible hosting. Sprint 2 details are reviewed on 2 November. The TA spreadsheet link is pending; it affects submission tracking but not test design. Test IDs from the supplied plan are preserved and additional cases fill coverage gaps.

12 Suspension and resumption

Suspend affected tests if the environment is unavailable for more than four hours, data integrity is compromised or blockers prevent >30% of planned cases. Continue independent tests where possible. Resume after environment/data recovery, blocker fix and smoke tests; rerun affected cases on the new commit.

13 Test cases and traceability

Common precondition: migrated isolated database and reachable test API; synthetic accounts exist unless the case creates one. Use the full /api/v1 prefix. Every case starts with status N (Not run). Requirement mappings below and SRS section 8 form the RTM.

TC-AUTH-01 | F-001

Register a unique allowed-domain email with valid fields. Expect 201, student role and one persisted user; response excludes hash.

Initial status: N | Actual result and evidence: not yet recorded.

TC-AUTH-02 | F-001

Repeat normalized email ->409; disallowed domain ->400; weak password or empty name ->422; no extra user rows.

Initial status: N | Actual result and evidence: not yet recorded.

TC-AUTH-03 | F-002

Log in as active registered user. Expect 200 token, expiresIn=1800 and exp-iat=1800.

Initial status: N | Actual result and evidence: not yet recorded.

TC-AUTH-04 | F-002

Use wrong password and unknown email. Both return identical 401 code/message and no token.

Initial status: N | Actual result and evidence: not yet recorded.

TC-AUTH-05 | F-003, SR-002

Obtain two tokens; logout with one ->204. Both tokens then fail protected GET with 401. New login succeeds.

Initial status: N | Actual result and evidence: not yet recorded.

TC-AUTH-06 | F-003, SR-002

Create a correctly signed token with past exp. Protected GET ->401 without modifying data.

Initial status: N | Actual result and evidence: not yet recorded.

TC-PRF-01 | F-004

GET profile, PUT name/department/location, then GET. Expect 200 and persisted values for this user only.

Initial status: N | Actual result and evidence: not yet recorded.

TC-PRF-02 | F-004, SR-005

PUT role=admin, email, active or password_hash. Expect 422 and unchanged protected fields.

Initial status: N | Actual result and evidence: not yet recorded.

TC-LST-01 | F-010

Authenticated owner creates valid listing ->201 AVAILABLE. Repeat ISBN for another copy: one book, separate listing. No token ->401.

Initial status: N | Actual result and evidence: not yet recorded.

TC-LST-02 | F-010

Send empty title, invalid ISBN length or invalid condition separately. Expect 422 naming field; no listing inserted.

Initial status: N | Actual result and evidence: not yet recorded.

TC-LST-03 | F-011

Seed distinct titles/authors, ISBNs and locations. Search each and combined filters. Only qualifying AVAILABLE non-deleted listings appear.

Initial status: N | Actual result and evidence: not yet recorded.

TC-LST-04 | F-011

Unknown query ->200 empty items. Compare page 1/2 slices and total; size=101 and page=0 ->422; tie ordering stable.

Initial status: N | Actual result and evidence: not yet recorded.

TC-LST-05 | F-012

Owner changes condition/status ->200 and persists. Other student ->403. Missing/deleted ID ->404. Reserved listing cannot be made available.

Initial status: N | Actual result and evidence: not yet recorded.

TC-LST-06 | F-013

Owner deletes idle listing ->204, deleted_at set. Verify absent in public and mine lists; repeated delete ->404.

Initial status: N | Actual result and evidence: not yet recorded.

TC-LST-07 | F-013

Sprint 1: patch has_active_exchange true; deletion ->409 and no timestamp change. Sprint 2: create real active exchange and repeat without a mock.

Initial status: N | Actual result and evidence: not yet recorded.

TC-LST-08 | F-011

Create listings for A and B including unavailable/deleted entries. A calls mine: only A non-deleted listings, including unavailable; no token ->401.

Initial status: N | Actual result and evidence: not yet recorded.

TC-REQ-01 | F-020

Create request with ISBN or query ->201 OPEN. Empty criteria ->422. Same user/active criteria ->409; another user remains independent.

Initial status: N | Actual result and evidence: not yet recorded.

TC-REQ-02 | F-021

Owner cancels open request ->200 CANCELLED and pending matches invalidated. Non-owner ->403; active exchange request ->409.

Initial status: N | Actual result and evidence: not yet recorded.

TC-MAT-01 | F-022

Use fixed candidate fixtures with known relevance/location/condition scores. Assert exact score order and top-five cap; exclude own/deleted/inactive offers.

Initial status: N | Actual result and evidence: not yet recorded.

TC-MAT-02 | F-022

Run two simultaneous mutual acceptances competing for one listing using separate DB connections. Exactly one active exchange; loser ->409; no duplicate reservation.

Initial status: N | Actual result and evidence: not yet recorded.

TC-MAT-03 | F-022

Decline or expire a suggestion, change listing status, then recompute. No stale/unavailable result; deterministic tie ordering and correct empty state.

Initial status: N | Actual result and evidence: not yet recorded.

TC-MAT-04 | F-024

One participant accepts: no exchange/contact yet. Other accepts: one exchange/reservation. Repeat decision is safe; unrelated user ->403; stale match ->409.

Initial status: N | Actual result and evidence: not yet recorded.

TC-NOT-01 | F-023

Trigger match/decision/return; each intended user gets one event. Replay event ->no duplicate. Other user cannot view or mark it read.

Initial status: N | Actual result and evidence: not yet recorded.

TC-EXC-01 | F-025

Participants agree future due date, lender hands over ->ON_LOAN. Borrower handover ->403; unagreed/past date ->409/422. Cancel before handover releases listing; after handover ->409.

Initial status: N | Actual result and evidence: not yet recorded.

TC-EXC-02 | F-026

First return confirmation keeps ON_LOAN; second ->RETURNED and listing AVAILABLE. Repeated calls do not duplicate events or change completed state.

Initial status: N | Actual result and evidence: not yet recorded.

TC-HIS-01 | F-030

Query paginated history for two users and an unrelated user. Each sees only exchanges they participate in with correct state/dates.

Initial status: N | Actual result and evidence: not yet recorded.

TC-RAT-01 | F-031

Rate partner after RETURNED ->201; self, pre-return, duplicate and out-of-range ratings rejected; recipient average recomputed correctly.

Initial status: N | Actual result and evidence: not yet recorded.

TC-ADM-01 | F-040

Admin deactivates user/hides listing with reason ->200 and audit row. Student ->403; missing reason ->422. Inactive user tokens/login fail.

Initial status: N | Actual result and evidence: not yet recorded.

TC-ADM-02 | F-040

Admin reads audit ->200; student ->403; verify actor, target, action, time, reason and no password/token leakage.

Initial status: N | Actual result and evidence: not yet recorded.

TC-SEC-01 | SR-001

Inspect stored bcrypt hash (not plaintext), verify correct/wrong password; reject >72-byte input. Check API responses and captured logs contain neither passwords nor hashes.

Initial status: N | Actual result and evidence: not yet recorded.

TC-SEC-02 | SR-002

Tamper JWT, use none/other algorithm, wrong signature, missing token, inactive user and stale ver. Every protected call ->401; no data changed.

Initial status: N | Actual result and evidence: not yet recorded.

TC-SEC-03 | SR-003

On deployment verify HTTP redirects, HTTPS valid certificate and TLS >=1.2; reject unapproved CORS origin; inspect repository and logs for secrets. Do not send real credentials over HTTP.

Initial status: N | Actual result and evidence: not yet recorded.

TC-SEC-04 | SR-004

Use SQL-like payloads in q/title/location. They are treated as literal data or validation errors, never query syntax; no unrelated rows or SQL errors. HTML-looking titles render as text.

Initial status: N | Actual result and evidence: not yet recorded.

TC-SEC-05 | SR-005

Student B attempts update/delete of A listing ->403 and unchanged data. Test authenticated role/ownership enforcement directly at API, not only UI.

Initial status: N | Actual result and evidence: not yet recorded.

TC-SEC-06 | SR-006

Five failures then sixth attempt (wrong or correct password) ->429 with positive Retry-After. Advance clock beyond 15 minutes ->allowed. Success before threshold clears failures.

Initial status: N | Actual result and evidence: not yet recorded.

TC-SEC-07 | SR-007

Inspect listing/match/history/contact responses before mutual accept and as unrelated user: no email/contact. Mutual participants can access contact; cancellation revokes it.

Initial status: N | Actual result and evidence: not yet recorded.

TC-PERF-01 | NF-001

Seed 20 users, ~2,000 books and 10,000 listings. Locust: 50 users, ramp 10/s, 1 minute. Record p90<=2s, errors and host details; use full /api/v1/listings path.

Initial status: N | Actual result and evidence: not yet recorded.

TC-PERF-02 | NF-005

Use 1,000 requests and 10,000 listings; 10 concurrent callers, >=100 matching evaluations. Report p95<=2s, candidate accuracy, failures and environment.

Initial status: N | Actual result and evidence: not yet recorded.

TC-OPS-01 | NF-002

Collect five-minute /health probes during 2-7 Nov. Successful/total scheduled probes >=99%; separately count missing probes, sleep and outages. Attach source report.

Initial status: N | Actual result and evidence: not yet recorded.

TC-UX-01 | NF-003

At 360px width test labelled forms, keyboard access and no horizontal scroll. From logged-in Browse count <=5 clicks for create listing and search (exclude typing/tabbing). Verify empty/errors.

Initial status: N | Actual result and evidence: not yet recorded.

TC-CI-01 | NF-004

On a test branch introduce a lint/test/build failure and confirm gate blocks merge. Restore fixes; all jobs pass and coverage>=70%, Auth>85%. PR never deploys; green main triggers real deployment.

Initial status: N | Actual result and evidence: not yet recorded.

TC-PORT-01 | NF-006

Fresh clone, create local env from example, docker compose up --build. Check migrations, health and register/login/create/search without manual DB edits; record OS and versions.

Initial status: N | Actual result and evidence: not yet recorded.

14 Metrics and reporting

Execution rate = executed / planned in-scope cases; pass rate = passed / executed; requirement acceptance = requirements with all relevant cases passed / in-scope requirements. Report failed and blocked separately; never include Not run as passed. Report open defects by severity and age, backend/Auth coverage, search p90 and matching p95. Burndown tracks estimated completed stories, not test case count or hours elapsed.

Defect report fields: title, linked requirement/case/Jira key, environment/commit, reproduction steps, expected/actual, severity, owner and evidence. Critical: data loss, account takeover or double reservation; High: core flow unavailable or privacy/authorization failure; Medium: partial flow defect with workaround; Low: cosmetic defect. Retest fixes and regress nearby functions.

15 Approvals

Review	Owner	Status
Technical/test baseline	Nishkal, Abhiram, Manoj, Ravish	Pending team review
Course acceptance	TA / course evaluator	Pending; no signature claimed

Sources

Supplied Software Test Plan ATM template; updated Book-Exchange Platform Sprint 1 Task Plan PDF; TA dates; user-confirmed role swap; companion SRS v1.0 and SAD v1.0. No test execution evidence was supplied or generated during document authoring.